정보보안 캡스톤 · 백엔드와 전체 구조

외부 LLM 게이트웨이

외부 LLM 전송 전 사내 민감정보를 탐지·가림하여
안전하게 보호하는 보안 게이트웨이



01 · 문제 정의

사내 직원이 외부 LLM에 입력하는 정보

고객 개인정보

이름, 연락처, 이메일이 포함된 고객 응대 문서와 메일 원문

인증 정보 · 내부 주소

API 키, 비밀번호, 내부 IP가 포함된 오류 로그와 설정 파일

영업기밀

배합표, 계좌번호, 사건번호 등 업종별로 다른 핵심 정보

전송된 정보는 회수할 수 없고, 외부 LLM 사용을 금지하는 것도 현실적이지 않다. 따라서 전송 전에 민감정보를 검사하는 단계가 필요하다.

02 · 사용 대상

사용 대상: 직원, 개발자, 보안 담당자

크롬 확장

웹에서 ChatGPT · Claude를 쓰는 직원

확장 설치만으로 적용된다. 기존 사용 방식 그대로, 전송 직전에 자동 검사한다.

OpenAI 호환 API

사내 앱과 에이전트를 만드는 개발자

API 주소만 변경하면 모든 요청이 동일한 검사를 거친다. 도구 호출을 사용하는 에이전트도 지원한다.

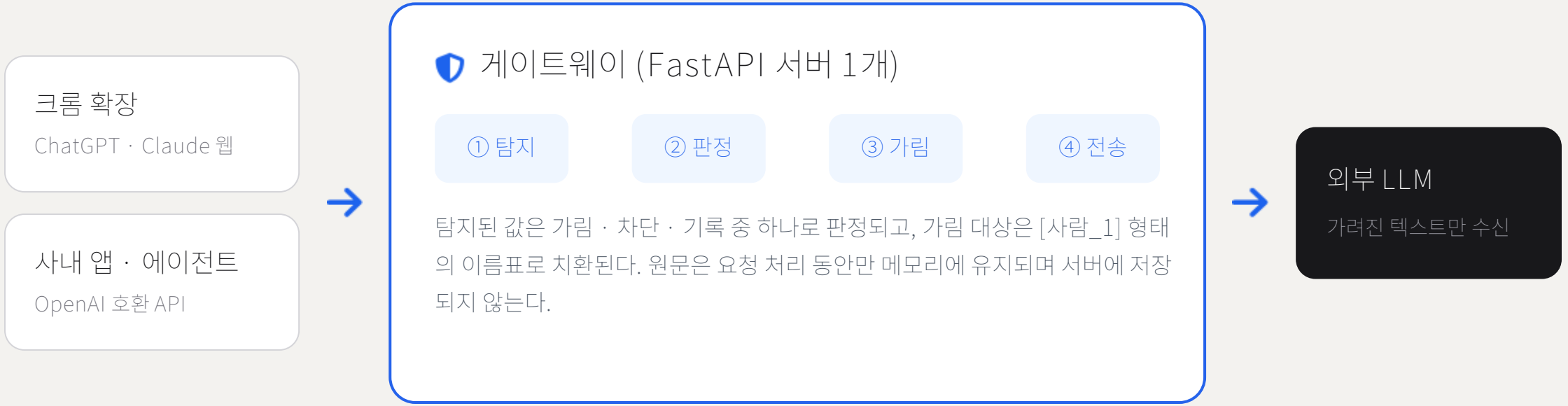
웹 콘솔

규칙과 예외를 다루는 보안 담당자

규칙 관리, 예외 요청 승인, 탐지 기록 조회를 한 화면에서 수행한다.

적용 대상 업종: 화장품, 금융, 의료, 제조, IT 등 보호 대상 정보가 업종별로 구분되는 분야

두 개의 입구, 하나의 게이트웨이, 외부로는 가려진 텍스트만



기록 항목 탐지 종류와 건수, 호출 주체, 사이트　　미기록 원문　　배포 Docker · Railway · 병합 전 자동 시험 4종

04 · 처리 방식

이름표 치환

입력 원문

고객 홍길동에게
메일 kim@corp.co.kr로
사과 메일 작성



외부 모델 수신 텍스트 (이름표 치환)

고객 [사람_1]에게
메일 [이메일_1]로
사과 메일 작성

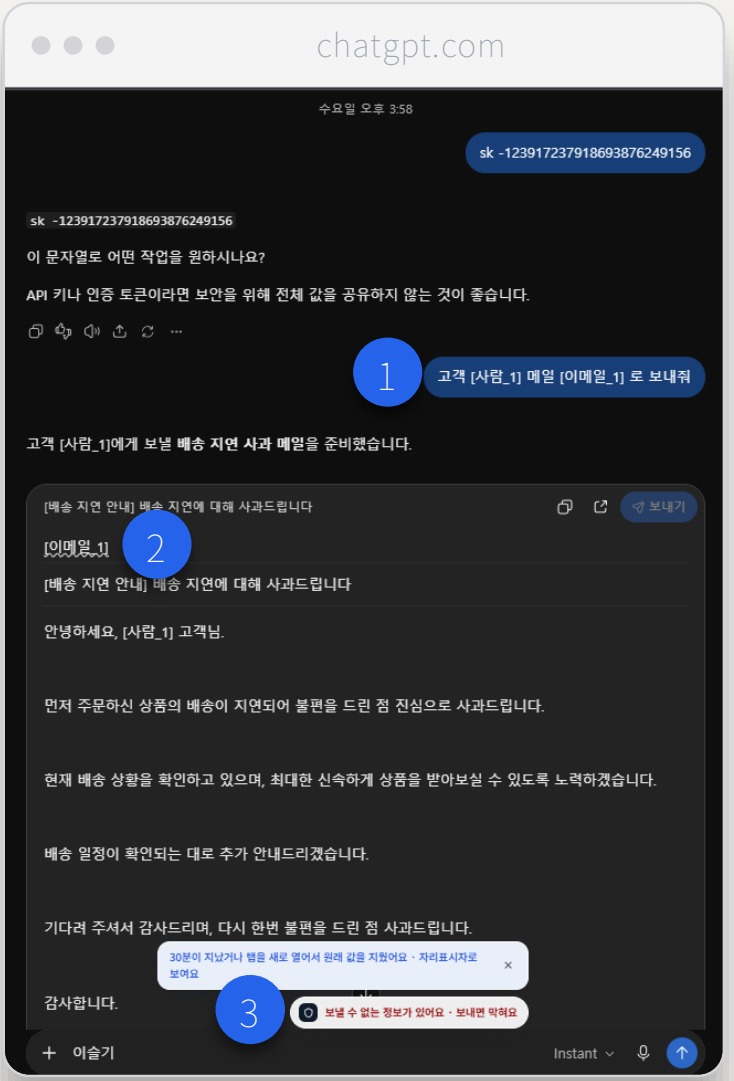
이름표를 쓰는 이유 단순 가림 문자로 바꾸면 모델이 작업을 수행할 수 없다. 정보 종류가 드러나는 이름표는 작업 맥락을 유지하면서 실제 값만 숨긴다.

구현 Presidio 등 오픈소스 PII 가림 도구와 동일한 방식. 라이브러리를 사용하지 않고 한국어 규칙과 업종 템플릿에 맞춰 직접 구현했다.

크롬 확장 적용 화면 (chatgpt.com)

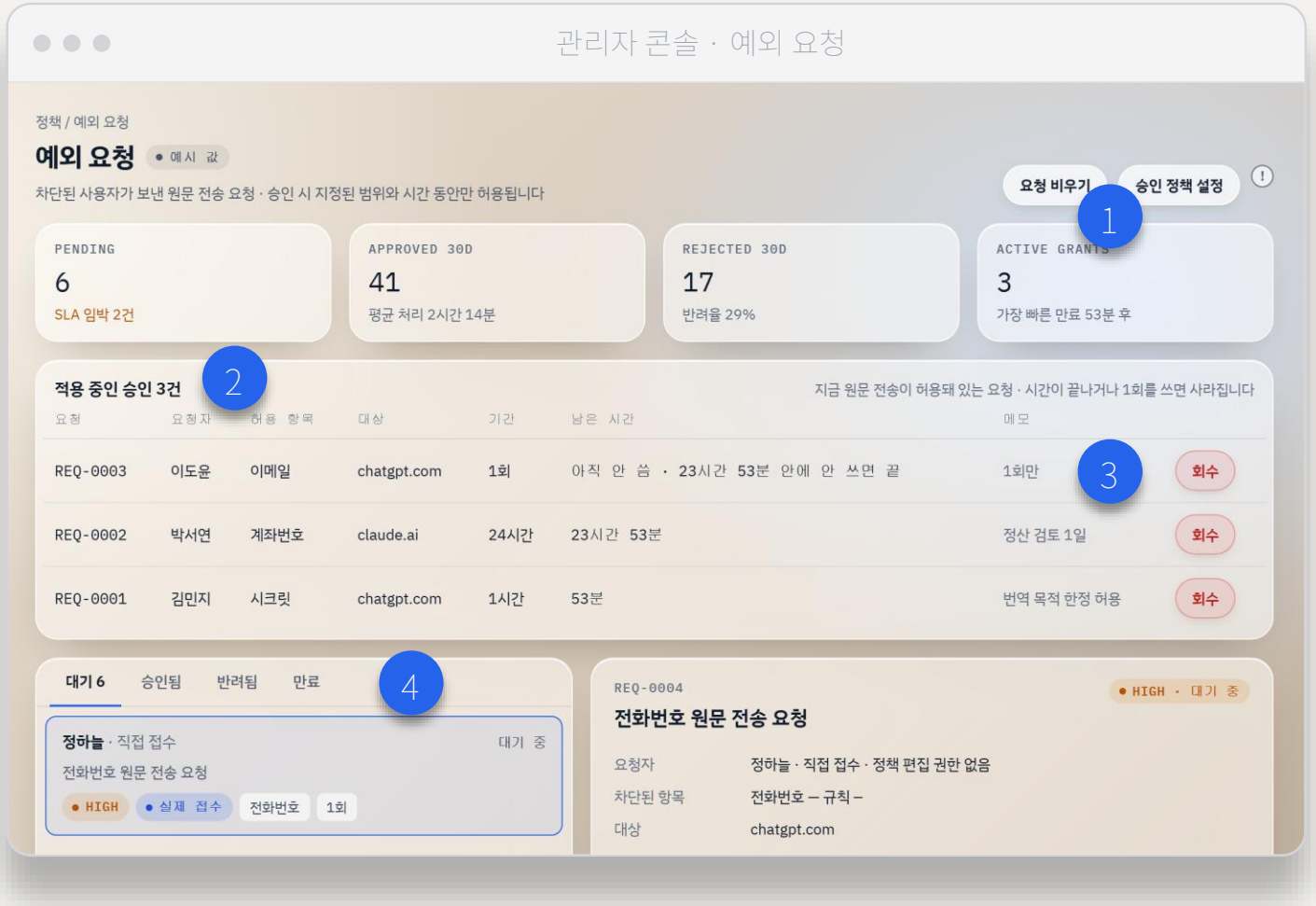
1. 이름표 치환 후 전송 입력 텍스트는 "고객 [사람_1] 메일 [이메일_1]" 형태로 변환되어 모델에 전달된다.
2. 이름표 기반 처리 모델은 실제 이름과 주소를 알지 못한 상태로 수신자가 [이메일_1]인 메일 초안을 생성한다.
3. 입력 중 사전 경고 API 키, IP 등 차단 대상이 포함되면 전송 전에 경고가 표시되고, 전송 시 차단된다.

일반 답변의 이름표는 원래 값으로 복원된다. 동일 창에서 30분 이내에만 적용되며, ChatGPT가 별도로 그리는 메일 카드 영역은 현재 복원 대상이 아니다.



관리자 콘솔 예외 승인의 적용과 회수

1. 적용 중 승인 건수 현재 원문 전송이 허용된 요청 수
2. 적용 중 승인 목록 요청자, 허용 항목, 대상 사이트, 잔여 시간. 1회 승인은 사용 즉시 종료
3. 회수 관리자가 승인을 즉시 종료하면 해당 항목은 다시 차단된다
4. 대기 요청 처리 요청 사유 확인 후 1회 · 1시간 · 24시간 · 7일 단위로 승인 또는 반려



07 · 탐지 구조

탐지는 세 층으로 나뉜다

1층 · 공통 규칙

기본 개인정보 (PII)

이메일, 주민번호, 전화번호, 사업자번호, 여권번호 등 어느 회사에나 공통인 정보. 한국 형식에 맞춰 직접 작성한 규칙

2층 · 오픈소스 규칙

비밀 정보

API 키, 비밀번호. 오픈소스 gitleaks 규칙(v8.30.1, MIT)을 저장소에 넣어 두어 실행 중에 내려받지 않는다

3층 · 직접 구현

업종 템플릿

업종을 알아야 정의할 수 있는 영업기밀. 팀이 직접 만든 부분

1·2층은 어느 회사에나 같다. 3층은 업종을 알아야 정의할 수 있고, 이 발표에서 다룰 부분이다.

08 · 업종 템플릿

같은 72.4%도 업종에 따라 기밀이 된다

일반 회사

" 시장 점유율 72.4%"

평범한 수치 · 그대로 전송

화장품 회사

" 정제수 72.4% 배합"

배합 비율 · 영업기밀 → 가림

현재 9개 업종 · 업종별로 지키는 정보

화장품(배합 비율·원료 공급사·배치번호) · 금융(계좌·카드번호·대출 금액·신용등급) · IT·개발(서버 주소·내부 IP) · 의료 · 법률 · 제조 · 물류 · 이커머스 · HR

파일 하나가 업종 하나. 회사는 자기 업종을 골라 켜기만 하면 되고, 코드 수정은 필요 없다.

09 · 템플릿 구조

템플릿 한 항목은 여섯 가지로 정의된다

예시 · IT · 개발 템플릿

내부 IP

이름표	[내부IP_1]
값의 모양	사설 IP 대역
주변 단어	IP · 서버 · 접속 …
동작	가림
중요도	보통
근거 법령	영업비밀보호법

이름표

가린 자리에 붙는 이름. 모델은 종류만 알고 값은 모른다

값의 모양

어떤 형태의 값을 찾을지 정한다

주변 단어

앞뒤 40자 안에 있어야 하는 단어. 오탐을 줄이는 핵심

동작

가림 · 차단 · 외부 전송 금지 중 실제 처리를 정한다

중요도

중요도 표시용 꼬리표. 가림·차단 판정에는 쓰이지 않는다

근거 법령

왜 보호해야 하는지 근거가 되는 법령

업종 담당자는 이 여섯 가지만 채우면 새 항목을 추가할 수 있다.

핵심은 모양과 문맥을 함께 보는 것

IT · 개발 · 가려짐

" 서버 IP 192.168.66.77"

'서버', 'IP'가 가까이 있음

IT · 개발 · 그대로 전송

" 버전 10.2.3.4 릴리스 노트"

버전 번호는 건드리지 않음

금융 · 가려짐

" 대출 한도 3억원"

'대출', '한도' 근처 금액만

실제 동작은 '동작'이 정한다: 조성비(중요도 최상)는 값만 가려서 전송하고, 원료 공급처(중요도 높음)는 외부로 내보내지 않는다. 모양만 보면 IP처럼 생긴 버전 번호까지 잡히므로 주변 단어를 함께 봐서 오탐을 줄인다.

템플릿마다 시험 문장을 함께 적는다

잡아야 할 문장과 정답

" 정제수 72.4% 배합 비율 공유" : 72.4%를 가림

" 배치번호: LOT240315A 출하" : LOT240315A를 가림

" 서버 IP 192.168.66.77" : IP 주소를 가림

건드리면 안 되는 문장

" 이번 분기 점유율 30% 상승" : 그대로 전송

" 버전 10.2.3.4 릴리스 노트" : 그대로 전송

평범한 업무 문장: 그대로 전송

업종 템플릿 자체 시험 통과 9 / 9

평범한 문장 오탐 (문서 기록 기준) 0건

규칙 방식을 고른 이유와 그 한계

학습 데이터 한계

실제 기밀 문서는 구할 수도 구해서도 안 되는 데이터

설명 가능

왜 가렸는지 항목과 주변 단어로 설명하고 매번 같은 결과 확인

바로 수정

재학습 없이 파일 하나만 고치면 즉시 반영

한계	원인	다음 단계
직함 없는 이름을 못 찾음 (예: "제 이름은 최민수")	규칙 기반 탐지	LLM 보조 탐지 검토
문서번호를 사업자번호로 오탐, 하이픈 없는 주민번호 누락	검증 숫자 미적용, 하이픈 필수	체크섬 검증 도입
정확도는 직접 만든 시험 문장 기준	업종당 3~17문장	실제 문서로 측정

시연: 가림 → 차단 → 예외 → 기록

1

가림

개인정보와 업종 기밀이 섞인 문장을 ChatGPT에 전송

검토 창에서 항목별로 가림 / 그대로 보냄을 고르면, 선택대로 전송되고 화면에는 ChatGPT가 받은 그대로 보인다

2

차단

API 키 모양의 가짜 값을 전송

전송이 막히고, 예외 요청 버튼이 나타난다

3

예외

요청하면 관리자가 콘솔에서 기간을 정해 승인

승인된 항목만 원문으로 나가고, 1회 승인은 한 번 쓰면 끝난다

4

기록

콘솔의 로그와 통계 확인

유형 · 건수 · 시각만 남고 원문은 저장하지 않는다. 예외를 쓴 기록에는 예외 표시

시연에 쓰는 이름, 주소, 키는 모두 예시 값이다.

질문 있으신가요?

Q&A

궁금한 점이 있으시면 편하게 질문해 주세요.